Organisatorische Resilienz II: Rollen und Verantwortlichkeiten

Vorlesungsskript · Sitzung 6 · Grundlagen der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Die mit „Hinweis zur Aktualität“ und „Ergänzung zur Vorlesung“ markierten Kästen sowie die Abbildungen wurden bei der Überführung ins Quarto-Projekt ergänzt. Der übrige Text entspricht dem Skript aus dem Wintersemester 2025/26; korrigiert wurden nur Tipp- und Umbruchfehler.

Kapitel 1 – Einleitung und Zielsetzung der Sitzung

In der vorherigen Sitzung wurde gezeigt, dass Resilienz nicht allein durch Technik entsteht, sondern durch Menschen, Kommunikation und Organisation. Sitzung 6 knüpft daran an und untersucht die **formalen Strukturen**, die Cyber-Resilienz in einer Organisation tragen: Rollen, Verantwortlichkeiten und Schnittstellen.

Resilienz bedeutet nicht, dass jeder alles kann – sondern dass **jeder weiß, wann er handeln muss und in welcher Rolle**. Damit eine Organisation im Krisenfall handlungsfähig bleibt, braucht sie klare Zuständigkeiten und trainierte Eskalationspfade.

Diese Sitzung verfolgt vier Lernziele:

1. **Verstehen**, welche zentralen Rollen (CISO, SOC, CERT, DPO, BCM, IT Ops, Management) in einer Cyber-Organisation existieren und wie sie zusammenspielen.
2. **Analysieren**, welche Aufgaben, Befugnisse und Grenzen diese Rollen haben.
3. **Erkennen**, wie organisatorische und kommunikative Schnittstellen Resilienz fördern oder behindern.
4. **Anwenden**, wie durch Rollenmodelle, Eskalationslogik und Governance eine belastbare Cyber-Struktur entsteht.

Ziel der Sitzung ist damit, die Frage zu beantworten:

„Wie wird aus Verantwortlichkeit Organisation – und aus Organisation Resilienz?“

Kapitel 2 – Vom Individuum zur Organisation: Warum Rollen entscheidend sind

Technische Resilienz hängt von Architektur ab – organisationale Resilienz von **Rollenklarheit**. In kritischen Situationen entscheidet nicht die Technologie, sondern die Fähigkeit, schnell und eindeutig zu handeln.

2.1 Rollen als Strukturprinzip

Rollen sind die **architektonischen Bausteine** organisatorischer Handlungsfähigkeit. Sie definieren Zuständigkeiten unabhängig von Personen und Hierarchie. So bleibt die Organisation handlungsfähig, selbst wenn Einzelpersonen ausfallen.

Eine Rolle beschreibt:

- **Verantwortung** (Wofür bin ich zuständig?)
- **Befugnis** (Was darf ich entscheiden?)
- **Schnittstellen** (Mit wem interagiere ich?)

Fehlt diese Klarheit, entstehen Doppelarbeiten, Verzögerungen und Konflikte – alles Faktoren, die in Krisen Resilienz massiv schwächen.

2.2 Verantwortung statt Schuld

Rollenorientierte Organisationen verschieben den Fokus von individueller Schuld auf kollektive Verantwortung. Fehler werden nicht personalisiert, sondern als Prozessprobleme verstanden. So entsteht ein Umfeld, in dem Menschen handeln, statt zu zögern.

2.3 Geschwindigkeit durch Struktur

Klar definierte Rollen und Eskalationspfade schaffen Geschwindigkeit, weil sie Entscheidungen **vorstrukturieren**. Ein Incident-Response-Team mit trainierter Rollenlogik kann in Minuten handeln, wo andere erst diskutieren, wer die Freigabe erteilt oder den Kommunikationsweg festlegt.

Kapitel 3 – Die Rolle des CISO: Verantwortung, Mandat und strategische Steuerung

Der **Chief Information Security Officer (CISO)** ist die Leitfigur für Informationssicherheit und Cyber-Resilienz. Er oder sie trägt die strategische Verantwortung dafür, dass Schutzmaßnahmen, Richtlinien und Prozesse nicht nur existieren, sondern wirksam ineinandergreifen.

In der Praxis steht der CISO an der Schnittstelle zwischen **Technik, Management und Governance**.

3.1 Mandat und Positionierung

Das Mandat des CISO ergibt sich in der Regel aus dem Informationssicherheits-Managementsystem (ISMS) nach ISO/IEC 27001.

Darin wird die Funktion als **verantwortlich für Aufbau, Umsetzung und Weiterentwicklung** der Informationssicherheitsstrategie beschrieben. Der CISO berichtet idealerweise direkt an die Geschäftsführung oder den Vorstand, um **Unabhängigkeit und Autorität** zu gewährleisten.

Kernverantwortlichkeiten:

- Entwicklung und Pflege der **Sicherheitsstrategie**
- Steuerung und Auditierung des **ISMS**
- Leitung des **Incident-Management-Prozesses** und Koordination mit SOC/CERT
- **Risikokommunikation** an Management und Aufsicht
- Sicherstellung regulatorischer **Compliance** (z. B. NIS-2, DSGVO, KRITIS-Vorgaben)
- Förderung der **Sicherheitskultur** im Unternehmen

Eine zu tiefe Einbettung des CISO in die IT-Linie birgt die Gefahr, dass wirtschaftliche Zielkonflikte (Verfügbarkeit vs. Sicherheit) nicht objektiv adressiert werden.

Deshalb fordern viele Standards (z. B. NIS-2-Richtlinie, ISO/IEC 27001:2022, BSI-Grundschutz) eine **klare organisatorische Trennung zwischen IT-Betrieb und Informationssicherheitsleitung**.

3.2 Das Mandatsdilemma

In der Praxis kämpfen viele CISOs mit einem **Mandatsdefizit**: Sie tragen Verantwortung, aber keine formale Entscheidungsgewalt oder ausreichenden Ressourcen.

Dieses Spannungsfeld wird häufig als *„Accountability without Authority"* bezeichnet. Resiliente Organisationen lösen dieses Dilemma, indem sie:

1. den CISO auf **strategischer Ebene** verankern,
2. ein festes **Budget und Reporting-Mandat** zuweisen,
3. und Eskalationsrechte in Richtlinien dokumentieren.

Dadurch wird Informationssicherheit zur **Führungsaufgabe**, nicht zum rein technischen Teilgebiet der IT.

3.3 Der CISO als Enabler von Resilienz

Ein moderner CISO ist kein „Security-Polizist", sondern ein **Business-Partner**. Er übersetzt technische Risiken in **betriebswirtschaftliche Entscheidungsgrundlagen** und trägt damit aktiv zur Resilienz des Unternehmens bei.

Schlüsselkompetenzen eines resilienten CISO:

- **Kommunikationsfähigkeit**: komplexe Risiken managementtauglich darstellen
- **Verhandlungsgeschick**: Sicherheit gegen andere Unternehmensinteressen abwägen
- **Krisenführung**: im Incident-Fall Prioritäten setzen, Ruhe bewahren
- **Adaptivität**: Lehren aus Incidents in Strategie und Richtlinien überführen

Der CISO ist damit nicht nur Hüter der Informationssicherheit, sondern **Architekt organisationaler Lernfähigkeit**. Er schafft die Brücke zwischen Technik, Organisation und Kultur.

3.4 Fazit

„Ein CISO ohne Mandat ist wie ein Pilot ohne Steuerknüppel."

Der CISO kann Resilienz nur dann wirksam gestalten, wenn seine Position im Unternehmen **strategisch anerkannt, ressourcenmäßig ausgestattet und kommunikativ eingebettet** ist. In resilienten Organisationen ist der CISO **nicht der Verhinderer**, sondern der **Ermöglicher** sicherer und stabiler Geschäftstätigkeit.

Kapitel 4 – Das Security Operations Center (SOC) als sensorisches Nervensystem der Resilienz

Das **Security Operations Center (SOC)** ist das **Frühwarn- und Überwachungssystem** einer Organisation.

Hier werden Datenflüsse beobachtet, Anomalien erkannt und Sicherheitsereignisse bewertet.

Im Resilienzkonzept übernimmt das SOC die Rolle des **Sensoriums** – es erkennt die Signale, auf die CERT und Management reagieren müssen.

4.1 Aufgaben und Funktionsweise

Ein SOC überwacht kontinuierlich Systeme, Netzwerke und Applikationen auf sicherheitsrelevante Ereignisse. Dazu werden Logdaten aus verschiedenen Quellen (Firewalls, Endpoint Security, Server, Cloud-Plattformen usw.) gesammelt, korreliert und bewertet.

Herzstück ist dabei das **Security Information and Event Management (SIEM)**, das Datenströme aggregiert und mit Use Cases bzw. Regeln abgleicht.

Typische Aufgabenbereiche:

- **Monitoring & Detection:** Erkennen verdächtiger Aktivitäten oder Policy-Verstöße
- **Analysis & Classification:** Bewertung von Alarmen und Korrelation mit Bedrohungsdaten
- **Incident Escalation:** Übergabe bestätigter Vorfälle an das CERT
- **Threat Intelligence:** Auswertung externer Bedrohungsquellen
- **Reporting:** Erstellung von Lagebildern und KPIs

Im Ergebnis fungiert das SOC als **Frühwarnsystem**, das Störungen in Echtzeit sichtbar macht – vergleichbar mit einem Radar für Cyberbedrohungen.

4.2 Tier-Modelle und Arbeitsteilung

Zur Strukturierung der Arbeit wird in SOCs meist ein **Tier-Modell** eingesetzt:

Ebene	Bezeichnung	Aufgabe
Tier 1 – Monitoring / Analysis	Erste Alarmbewertung, Triage, Eskalation	„Frontlinie“ des SOC
Tier 2 – Investigation	Vertiefte Analyse, Kontextbewertung, Angriffsketten-Erkennung	Threat-Analysten
Tier 3 – Response / Forensics / Threat Hunting	Technische Eindämmung, forensische Analyse, Angriffsnachverfolgung	Spezialistenebene

Dieses Schichtmodell erlaubt es, Ressourcen effizient zu nutzen und Reaktionszeiten zu verkürzen.

Resilienz entsteht hier durch **Funktionstrennung und Spezialisierung** – nicht durch Mehrarbeit.

4.3 Schnittstellen und Kommunikation

Das SOC ist eng mit anderen Organisationseinheiten verbunden:

Schnittstelle	Interaktion
CISO-Office	Reporting, Risikoeinschätzung, KPI-Übermittlung
CERT	Technische Übergabe von Incidents, Koordination der Response
IT Operations	Abstimmung über Maßnahmen (z. B. Isolierung, Abschaltung)
DPO / BCM	Informationsweitergabe bei Datenschutz- oder Kontinuitätsrelevanz
Management	Lagedarstellung, Eskalationen, Entscheidungsvorlagen

Diese Kommunikationsmatrix ist entscheidend für die Resilienz: Nur wenn Informationen schnell, eindeutig und abgestimmt fließen, wird aus Erkennung auch Reaktion.

4.4 Herausforderungen im SOC-Betrieb

- **Alarm Fatigue:** Zu viele Fehlalarme führen zu Reaktionsmüdigkeit.
- **Personalmangel:** Fachkräfte sind knapp, SOCs oft unterbesetzt.
- **Komplexität der Tool-Landschaft:** Viele Systeme → viele Daten → Analyseüberlastung.
- **Schnittstellenprobleme:** Unklare Übergaben zwischen SOC, IT und CERT.
- **Mangelnde Priorisierung:** Fehlende Abwägung zwischen Incident-Schwere und Business Impact.

Resiliente SOCs lösen diese Probleme durch:

- Automatisierung (z. B. SOAR-Plattformen),
- klare Playbooks,
- Priorisierung nach Risiko,
- kontinuierliches Training.

4.5 Das SOC als Teil des Resilienzsystems

In der Gesamtarchitektur der Cyber-Resilienz ist das SOC die erste Verteidigungslinie:

```
[ Bedrohung ] → [ SOC – Detection & Analysis ]
                          ↓
                  [ CERT – Response ]
                          ↓
               [ CISO – Strategie & Reporting ]
```

Damit trägt das SOC die Verantwortung, **relevante Signale von Rauschen zu trennen** und die Organisation in den Resilienzzyklus (Detection → Response → Recovery → Adapt) einzuspeisen.

„Resilienz beginnt mit Wahrnehmung – und Wahrnehmung beginnt im SOC."

Kapitel 5 – Das Computer Emergency Response Team (CERT) als operative Reaktionseinheit

Das **Computer Emergency Response Team (CERT)** ist die **taktische Einsatztruppe** der Cyber-Resilienz.

Während das SOC Sicherheitsvorfälle erkennt und analysiert, koordiniert das CERT die **technische Reaktion**, führt forensische Analysen durch und sorgt für Wiederanlauf, Dokumentation und Lessons Learned.

Es ist damit der **operative Kern des Incident-Response-Prozesses** und zentraler Bestandteil des organisationalen Resilienzzyklus.

5.1 Aufgaben und Mandat

Das Mandat des CERT umfasst alle Aktivitäten, die der **Eindämmung, Bewältigung und Nachbereitung** von Sicherheitsvorfällen dienen.

Kernaufgaben:

- **Incident Coordination:** Steuerung der technischen Reaktion auf bestätigte Sicherheitsvorfälle
- **Forensik und Ursachenanalyse:** Untersuchung von Angriffspfaden und Schwachstellen

- **Containment und Eradication:** Eindämmung der Ausbreitung, Beseitigung der Schadursache
- **Recovery-Unterstützung:** Koordination von Wiederanlaufmaßnahmen
- **Kommunikation:** Abstimmung mit CISO, IT Ops, DPO, BCM und externen Partnern (z. B. BSI, ENISA)
- **Lessons Learned:** Dokumentation und Rückführung in Richtlinien und Playbooks

In vielen Organisationen wird das CERT als **Spezialteam innerhalb oder neben dem SOC** aufgebaut.

Wichtig ist die **klare funktionale Trennung**: SOC erkennt, CERT reagiert – beide arbeiten eng, aber mit unterschiedlichen Schwerpunkten.

5.2 CERT-Arten und organisatorische Modelle

Typ	Beschreibung	Beispiel
Internal CERT	Zuständig für die eigene Organisation oder Unternehmensgruppe	Corporate CERT, Group CERT
National CERT	Koordiniert übergreifend auf staatlicher Ebene	CERT-Bund, GovCERT
Sectoral CERT	Branchenbezogene Zusammenarbeit	FinanceCERT, EnergyCERT
Academic CERT	CERTs in Forschung und Bildungseinrichtungen	DFN-CERT, EDU-CERT

Diese Vielfalt ermöglicht die **Vernetzung** zwischen Organisationen, Branchen und Behörden.

ENISA und FIRST (Forum of Incident Response and Security Teams) fördern den internationalen Austausch und Standardisierung.

5.3 Schnittstellen und Zusammenarbeit

Das CERT agiert als **Koordinationsstelle** zwischen Technik, Organisation und Management.

Seine Wirksamkeit hängt davon ab, wie gut diese Schnittstellen definiert sind.

Schnittstelle	Bedeutung
SOC	Übergabe von verifizierten Alerts, technische Lageberichte
CISO / ISMS	Entscheidungsgrundlage, Risikokommunikation, Reporting
IT Operations	Umsetzung von Maßnahmen (z. B. Isolierung, Wiederanlauf)
DPO / Legal	Prüfung rechtlicher Meldepflichten
Kommunikation / PR	Abstimmung externer Informationspolitik
Management Board	Freigabe von Ressourcen, strategische Entscheidungen

Je besser die Schnittstellen funktionieren, desto **schneller und koordinierter** kann das CERT reagieren.

Das ist der Kern organisatorischer Resilienz: **technische Präzision plus strukturelle Klarheit.**

5.4 CERT-Prozessmodell

Das CERT folgt in der Regel dem **Incident Handling Cycle** nach ISO/IEC 27035:

1. **Preparation** – Aufbau von Tools, Playbooks, Kommunikationswegen

2. **Detection & Reporting** – Übergabe bestätigter Incidents vom SOC
3. **Assessment & Prioritization** – Bewertung von Kritikalität und Business Impact
4. **Containment & Eradication** – Eindämmung und Beseitigung
5. **Recovery** – Wiederherstellung der Systeme und Services
6. **Lessons Learned** – Nachbereitung, Analyse, Verbesserung

Jede Phase erfordert definierte Verantwortlichkeiten und dokumentierte Verfahren. Dieser Zyklus wird oft als „Miniaturform des Resilienzzyklus“ verstanden – Detection → Response → Recovery → Adapt.

> ℹ Hinweis zur Aktualität
>
> ISO/IEC 27035-1 gliedert den Prozess gröber (u. a. Planen und Vorbereiten, Erkennen und Melden, Bewerten und Entscheiden, Reagieren, Lessons Learned) [1]. Die hier gezeigte feinere Gliederung entspricht eher NIST SP 800-61 Rev. 2. Siehe Quellen, Hinweis 9.

5.5 Erfolgskriterien eines resilienten CERT

1. **Klare Governance:** Mandat, Eskalationsrechte und Reporting-Linien müssen festgelegt sein.
2. **Trainierte Teams:** Regelmäßige technische und kommunikative Übungen (z. B. Red Team / Blue Team).
3. **Standardisierte Playbooks:** Handlungsanweisungen für typische Szenarien (Phishing, Ransomware, DDoS).
4. **Forensische Kompetenz:** Fähigkeit, Beweise gerichtsfest zu sichern und auszuwerten.
5. **Transparente Kommunikation:** Einheitliche Informationspolitik nach innen und außen.
6. **Nachbereitungskultur:** Incidents enden nicht mit Recovery, sondern mit Lernen.

Ein starkes CERT erkennt man daran, dass es nach einem Vorfall **besser vorbereitet ist als zuvor**.

5.6 Fazit

„Das CERT ist das Immunsystem der Organisation – es reagiert, bekämpft, heilt und erinnert.“

Ohne ein klar definiertes, handlungsfähiges CERT bleibt Incident Response reaktiv. Resilienz entsteht erst, wenn technische Expertise mit organisatorischem Lernen verbunden wird.

Das CERT ist der Ort, an dem beides zusammenkommt.

Kapitel 6 – Zusammenarbeit und Abgrenzung von SOC, CERT und CISO

CISO, SOC und CERT bilden das **Kernsystem organisationaler Cyber-Resilienz**. Sie sind drei Perspektiven auf dasselbe Ziel: Angriffe rechtzeitig erkennen, adäquat reagieren und aus Vorfällen lernen. Ihre Beziehung folgt dem Prinzip **„Trennung der Funktionen – Integration der Wirkung“**.

6.1 Die funktionale Triade

Funktion	Ebene	Hauptaufgabe	Zeithorizont
CISO	Strategisch	Governance, Risiko, Compliance, Management-Reporting	langfristig

Funktion	Ebene	Hauptaufgabe	Zeithorizont
SOC	Operativ	Monitoring, Erkennung, Analyse	kurzfristig
CERT	Taktisch	Reaktion, Eindämmung, Wiederherstellung	mittelfristig

Diese Dreiteilung vermeidet Interessenkonflikte und schafft **Redundanz in der Verantwortung**: Wenn das SOC versagt, erkennt es das CERT; wenn Prozesse versagen, greift die Governance des CISO.

6.2 Kommunikations- und Eskalationslogik

Die Effektivität dieser Triade hängt nicht von Hierarchie, sondern von **Informationsfluss und Vertrauen** ab.

Beispielhafte Eskalationskette:

```
  CISO (Strategie, Entscheidung)
         ↑
CERT (Response, Coordination)
         ↑
SOC (Detection, Monitoring)
```

Jede Eskalationsstufe erfüllt eine eigene Rolle:

- **SOC → CERT:** Meldung bestätigter Incidents mit technischer Analyse
- **CERT → CISO:** Bewertung von Kritikalität, Entscheidungsempfehlung, Ressourcenbedarf
- **CISO → Management:** Kommunikation, Risikoabwägung, externe Meldungen

Diese vertikale Linie wird ergänzt durch **horizontale Kommunikation**: zwischen CERT und IT Ops, zwischen CISO und DPO, zwischen SOC und Threat Intelligence.

Resilienz bedeutet hier **Synchronisation**, nicht Kontrolle.

6.3 Gemeinsames Lagebild

Ein resilientes Zusammenspiel setzt ein gemeinsames Lagebild voraus – eine „Single Source of Truth“ für Sicherheits- und Vorfalldaten. Typische Instrumente:

- **SIEM / SOAR-Plattformen** als technische Integratoren
- **Cyber Situation Reports** (z. B. tägliche oder wöchentliche Lageberichte)
- **Incident Dashboards** für Management und CISO
- **Lessons-Learned-Datenbanken** als Wissensspeicher

„Was das SOC sieht, muss das CERT wissen – und was das CERT lernt, muss der CISO verstehen.“

Fehlt ein gemeinsames Lagebild, entstehen Lücken: Die Technik erkennt, das Management entscheidet, aber niemand sieht das Gesamtbild.

6.4 Governance und Abgrenzung

Governance-Prinzipien für das Zusammenspiel:

1. **Dokumentierte Rollenbeschreibungen:** Jede Funktion hat definierte Aufgaben, Verantwortlichkeiten und Eskalationsrechte (nach ISO/IEC 27035 und ISO/IEC 27001).
2. **Formalisierte Übergabepunkte:** Klare Kriterien, wann ein SOC-Alert zum CERT-Case wird.
3. **Dual Reporting:** CERT berichtet operativ an den CISO, technisch an die IT.
4. **Regelmäßige Abstimmungen:** Tägliche Stand-ups bei Incidents, monatliche Review-Meetings.
5. **Lessons-Learned-Kultur:** Nachbereitung erfolgt gemeinsam, nicht isoliert.

Die **Trennung von Governance und Operation** ist ein Kernelement der Resilienz. Nur so kann Kontrolle, Überprüfung und Lernen systematisch stattfinden.

6.5 Herausforderungen in der Praxis

- **Silo-Strukturen:** Fehlende Kommunikation oder Misstrauen zwischen SOC, CERT und CISO
- **Priorisierungskonflikte:** Sicherheit vs. Verfügbarkeit
- **Ressourcendruck:** Überlastete Teams, fehlende Eskalationswege
- **Tool-Fragmentierung:** Inkompatible Systeme behindern Lagebildbildung
- **Mangelndes Verständnis:** Management sieht „Security“ oft als Kostenstelle

Resiliente Organisationen begegnen diesen Herausforderungen durch:

- Gemeinsame Trainings (z. B. SOC–CERT–CISO Tabletop Exercises)
- Klare KPIs für Reaktionszeit, Kommunikationsgeschwindigkeit, Recovery-Dauer
- CISO-Sponsorship im Management
- Standardisierte Kommunikationsplattformen

6.6 Fazit

„Resilienz ist Teamarbeit – aber nur, wenn das Team dieselbe Sprache spricht.“

CISO, SOC und CERT sind keine isolierten Silos, sondern arbeitsteilige Module eines lernenden Systems. Ihre Effektivität entsteht aus **klarer Abgrenzung, strukturiertem Informationsfluss und gelebtem Vertrauen**.

Wo diese drei Rollen harmonieren, wird Cyber-Resilienz zur Organisationseigenschaft – nicht nur zur Strategie.

Kapitel 7 – Weitere Schlüsselrollen in der Cyber-Organisation: DPO, BCM, IT Operations und Management Board

Cyber-Resilienz ist kein exklusives Thema für IT und Security. Sie entsteht erst dann nachhaltig, wenn **Datenschutz, Business Continuity, IT-Betrieb und Management** in das Sicherheitsökosystem integriert sind.

Diese Rollen bilden den organisatorischen Rahmen, in dem SOC, CERT und CISO effektiv agieren können.

7.1 Der Data Protection Officer (DPO)

Der Datenschutzbeauftragte ist gesetzlich (Art. 37–39 DSGVO) vorgeschrieben und fungiert als **Schnittstelle zwischen Technik, Recht und Aufsicht**.

Kernaufgaben:

- Überwachung der DSGVO-Compliance

- Bewertung von Datenschutzvorfällen
- Beratung zu Datenverarbeitung und Informationssicherheit
- Kommunikation mit Aufsichtsbehörden
- Mitarbeit bei Awareness-Maßnahmen

Bezug zur Resilienz: Im Incident-Fall (z. B. Datenabfluss) bewertet der DPO die **Meldepflicht gemäß Art. 33 DSGVO** und arbeitet eng mit CERT, CISO und PR zusammen. Ein klar definierter Kommunikationsweg zwischen CERT und DPO vermeidet Fehlinformationen oder verspätete Meldungen.

„Datenschutz ist kein Gegner der Resilienz – sondern ihr rechtliches Rückgrat."

7.2 Der BCM-Manager (Business Continuity Management)

Das BCM (nach ISO 22301 und BSI 200-4) stellt sicher, dass kritische Geschäftsprozesse auch unter Krisenbedingungen fortgeführt werden können.

Kernaufgaben:

- Identifikation kritischer Geschäftsprozesse (Business Impact Analysis)
- Entwicklung und Pflege von Notfallplänen
- Koordination von Wiederanlaufmaßnahmen (Disaster Recovery)
- Durchführung regelmäßiger Übungen und Tests

Bezug zur Resilienz:

Während CERT und SOC den Cyber-Aspekt behandeln, sichert das BCM die **betriebliche Resilienz** – also den Fortbestand des Geschäftsmodells.

Gemeinsam bilden sie die **operative und organisatorische Resilienzachse**.

„Das CERT schützt Systeme – das BCM schützt den Zweck."

7.3 IT Operations

IT Ops ist das **Rückgrat der Verfügbarkeit**. Ohne stabile und transparente Betriebsprozesse kann keine Sicherheitsmaßnahme wirksam greifen.

Aufgaben:

- Betrieb und Wartung von Infrastruktur und Anwendungen
- Umsetzung von Wiederanlaufmaßnahmen nach CERT-Anweisung
- Dokumentation und Versionskontrolle
- Kommunikation mit Nutzern und Service Management

Bezug zur Resilienz: IT Ops ist im Incident-Fall sowohl **Betroffener als auch Akteur**. Resiliente Organisationen binden IT Ops aktiv in CERT-Übungen und Lessons Learned ein, um technische und organisatorische Perspektiven zu verknüpfen.

„Recovery ist keine IT-Aufgabe – sondern eine Teamleistung, an der IT Ops entscheidend beteiligt ist."

7.4 Das Management Board

Das Management ist **Träger der Gesamtverantwortung** für Informationssicherheit und Resilienz.

Gemäß NIS-2-Richtlinie (EU 2022/2555) und ISO/IEC 27001:2022 muss die Leitung nachweislich Verantwortung für Sicherheits- und Resilienzmaßnahmen übernehmen.

> **i** Hinweis zur Aktualität
>
> Die NIS-2-Richtlinie ist die Richtlinie (EU) 2022/2555 vom 14. Dezember 2022 [2]; die Nummer wurde im Text berichtigt. Siehe Quellen, Hinweis 4.

Kernaufgaben:

- Genehmigung der Sicherheitsstrategie
- Bereitstellung von Ressourcen und Budget
- Bewertung und Akzeptanz von Risiken
- Teilnahme an Krisen- und Kommunikationsübungen
- Entscheidung über externe Kommunikation und Meldepflichten

Bezug zur Resilienz: Ein Management, das Verantwortung sichtbar lebt, prägt die Sicherheitskultur und legitimiert die Arbeit von CISO, SOC und CERT. In der Praxis bedeutet das: **Resilienz ist Chefsache.**

„Resilienz ohne Leadership bleibt ein Konzept – mit Leadership wird sie Kultur."

7.5 Zusammenspiel der Schlüsselrollen

Rolle	Primäre Aufgabe	Schnittstellen
DPO	Datenschutz & rechtliche Compliance	CERT, CISO, Legal
BCM	Geschäftsfortführung	CERT, IT Ops, Management
IT Ops	Technischer Betrieb	CERT, SOC, BCM
Management	Strategische Steuerung & Ressourcen	CISO, DPO, BCM

Dieses Zusammenspiel sorgt dafür, dass Cyber-Resilienz **nicht in der IT steckenbleibt**, sondern zur gesamtunternehmerischen Fähigkeit wird.

7.6 Fazit

Resilienz ist kein Produkt einzelner Spezialisten, sondern das Ergebnis **kollektiver Verantwortlichkeit**. Wo Datenschutz, IT-Betrieb, Business Continuity und Führung zusammenwirken, entsteht ein System, das **nicht nur reagiert, sondern stabil führt**.

„Eine Organisation ist dann resilient, wenn alle Rollen dieselbe Sprache sprechen – und dieselbe Richtung kennen

Kapitel 8 – Kommunikations- und Eskalationsmodelle in resilienten Cyber-Organisationen

Resilienz entsteht nicht nur aus Struktur, sondern aus **koordiniertem Informationsfluss**. In Krisensituationen entscheidet die **Qualität und Geschwindigkeit der Kommunikation** über den Erfolg der technischen und organisatorischen Reaktion.

Fehlkommunikation ist laut BSI und ENISA einer der häufigsten Verstärker von Sicherheitsvorfällen.

Deshalb braucht jede Organisation ein **definiertes Kommunikations- und Eskalationsmodell**, das Zuständigkeiten, Kanäle und Schwellenwerte verbindlich regelt.

8.1 Grundprinzipien resilienter Kommunikation

1. **Klarheit:** Wer informiert wen, über welchen Kanal, mit welchem Ziel?

2. **Redundanz:** Wichtige Informationen müssen mehr als einen Pfad erreichen.
3. **Priorisierung:** Nicht alles ist sofort relevant – Eskalation nach Schweregrad.
4. **Vertraulichkeit:** Informationen folgen dem Need-to-know-Prinzip.
5. **Bidirektionalität:** Rückmeldungspflicht – jede Information erzeugt eine Antwort.

„Kommunikation ist keine Nebensache im Incident – sie *ist* der Incident."

Diese Prinzipien gelten unabhängig von der Organisationsgröße und sollten im Rahmen des ISMS regelmäßig geübt und evaluiert werden.

8.2 Beispielhafte Eskalationsstruktur

Ein praxisorientiertes Kommunikationsmodell lässt sich wie folgt darstellen:



Ebenen der Kommunikation:

- **Operativ (SOC, IT Ops):** technische Meldungen und Status-Updates
- **Taktisch (CERT, DPO, BCM):** Reaktionskoordination, Priorisierung
- **Strategisch (CISO, Management):** Entscheidungen, Ressourcen, externe Kommunikation

Die Verbindung dieser Ebenen erfordert definierte **Eskalationszeiten** (z. B. SOC → CERT innerhalb von 15 Minuten, CERT → CISO innerhalb von 30 Minuten).

8.3 Kommunikationskanäle und Tools

Resiliente Organisationen trennen Alltagskommunikation von Krisenkommunikation. **Bewährte Werkzeuge:**

- **Krisenkanäle** (z. B. Microsoft Teams „Crisis Room", Slack Incident Channel)
- **Hotlines / War Rooms** mit direkter Leitung zu CISO und CERT
- **Automatisierte Alarmierungen** über SIEM oder SOAR-Systeme
- **Incident Management Tools** (z. B. Jira Service Management, PagerDuty)
- **Offline-Fallback-Kanäle** bei Netzwerkausfall (z. B. Mobiltelefone, SMS, Notebooks mit LTE)

Ein robustes Kommunikationsmodell berücksichtigt auch den **Ausfall digitaler Systeme**. Cyber-Resilienz ohne Kommunikationsresilienz bleibt Illusion.

8.4 Informationsklassifikation und Meldepflichten

Kommunikation im Incident-Fall unterliegt auch rechtlichen Anforderungen:

- **DSGVO Art. 33:** Meldung personenbezogener Datenpannen innerhalb von 72 Stunden
- **NIS-2 (EU 2022/2555):** Frühwarn- und Endberichte an zuständige Behörden
- **BSI-Gesetz (§ 8b):** Meldepflichten für Betreiber kritischer Infrastrukturen

> **i** Hinweis zur Aktualität
>
> Das BSI-Gesetz wurde durch das NIS-2-Umsetzungsgesetz (in Kraft seit 6. Dezember 2025) neu gefasst. Der Verweis auf § 8b BSIG bezieht sich auf die alte Fassung; die Meldepflichten stehen jetzt in der Neufassung. Siehe Quellen, Hinweis 5.

Daraus ergibt sich die Notwendigkeit, Incident-Typen **vorab zu klassifizieren** und **Verantwortlichkeiten festzulegen**:

Kategorie	Meldepflicht	Ansprechpartner
Technischer Sicherheitsvorfall	Nein	CERT, CISO
Datenschutzrelevanter Vorfall	Ja (Art. 33 DSGVO)	DPO
Kritische Infrastruktur betroffen	Ja (BSIG, NIS-2)	CISO, Management
Betriebsunterbrechung > x h	BCM relevant	BCM-Manager

„Nicht jeder Incident ist meldepflichtig – aber jeder muss dokumentiert werden."

8.5 Der menschliche Faktor

Auch das beste Kommunikationsmodell scheitert, wenn Menschen zögern oder Informationen zurückhalten. Psychologische Sicherheit (vgl. Amy Edmondson, 1999) ist daher ein Schlüsselfaktor: Mitarbeitende müssen sich trauen, **Fehler und Unsicherheiten** frühzeitig zu melden, ohne negative Konsequenzen befürchten zu müssen.

Resiliente Teams zeichnen sich aus durch:

- Vertrauen statt Schuldzuweisung
- Offene Rückfragenkultur
- Aktives Zuhören
- Prägnante Sprache („BLUF" – *Bottom Line Up Front*)

8.6 Fazit

Kommunikation ist der **Transmissionsriemen der Resilienz**. Sie verbindet Rollen, Prozesse und Technik zu einem lernenden System.

Ohne definierte Kommunikations- und Eskalationswege kann keine Organisation schnell, kohärent oder transparent reagieren.

„Resilienz zeigt sich nicht in der Verfügbarkeit von Tools, sondern in der Klarheit von Sprache und Verantwortung."

Kapitel 9 – Typische Konfliktlinien und Lösungsprinzipien zwischen Rollen

In der Theorie sind Rollen klar definiert.

In der Praxis jedoch treffen unterschiedliche Zielsysteme, Perspektiven und Sprachen aufeinander.

Ein SOC denkt in Alarmen, ein BCM in Geschäftsprozessen, ein Management Board in Reputationsrisiken – und der CISO muss alles übersetzen.

Organisatorische Reibung ist deshalb kein Fehler, sondern **ein Symptom lebender Systeme**.

Resilienz bedeutet, diese Spannungen **sichtbar zu machen und konstruktiv zu steuern**.

9.1 Warum Konflikte unvermeidlich sind

Jede Rolle folgt einem anderen **Optimierungskriterium**:

Rolle	Primäres Ziel	Typische Perspektive
CISO	Minimierung von Risiko	strategisch
SOC	Detektion und Geschwindigkeit	operativ-technisch
CERT	Eindämmung und Wiederherstellung	taktisch
IT Ops	Verfügbarkeit und Stabilität	betrieblich
DPO	Rechtssicherheit und Datenschutz	compliance-orientiert
Management	Geschäftskontinuität und Kosten	wirtschaftlich

Diese divergierenden Ziele führen zwangsläufig zu **Interessenkonflikten**, insbesondere unter Drucksituationen, in denen Zeit und Informationen knapp sind.

9.2 Typische Konfliktlinien

Konfliktfeld	Ursache	Beispiel
CISO vs. CIO	Priorität von Sicherheit vs. Verfügbarkeit	„Patch einspielen“ vs. „System darf nicht ausfallen“
SOC vs. IT Ops	Eingriffsrechte in produktive Systeme	SOC möchte Server isolieren, IT Ops verweigert Freigabe
CERT vs. PR	Kommunikationsgeschwindigkeit vs. Reputationsrisiko	CERT will transparent kommunizieren, PR will abwarten
DPO vs. CERT	Datenschutzmeldung vs. forensische Datenweitergabe	Daten dürfen nicht ohne rechtliche Prüfung geteilt werden
BCM vs. Security	Wiederanlauf vs. Ursachenanalyse	BCM drängt auf Recovery, CERT braucht Beweissicherung

Diese Spannungen sind keine Schwäche, sondern ein Hinweis auf **komplexe Verantwortungsteilung**.

Resilienz heißt, Mechanismen zu schaffen, die diese Konflikte **kontrolliert austragen** lassen.

9.3 Lösungsprinzipien resilienter Organisationen

1. **Governance durch Klarheit**

   Jede Rolle hat eine dokumentierte Entscheidungs- und Eskalationsbefugnis.

   → *Verantwortung ersetzt Diskussion.*

2. **Kommunikation durch Standardisierung**

   Gemeinsame Kommunikationsprotokolle (z. B. Incident Reports, Templates, BRIEF-Format) reduzieren Missverständnisse zwischen Technik, Recht und Management.

3. **Entscheidung durch Vorbereitung**

   Tabletop-Übungen simulieren Entscheidungsprozesse im Vorfeld realer Krisen.

   → Rollen lernen, wo Reibung entsteht, bevor sie kritisch wird.

4. **Priorisierung durch Business Impact**

   Nicht jede technische Bedrohung ist gleich kritisch. Entscheidungen werden am **Geschäftsrisiko**, nicht am Alarmpegel orientiert.

5. **Vertrauen durch Kultur**

   Wer sich sicher fühlt, auch Unsicherheiten zu äußern, trägt zu schnellerer und ehrlicher Kommunikation bei.

   → Psychologische Sicherheit als Resilienzfaktor (vgl. Edmondson, 1999).

9.4 Beispielhafte Governance-Matrix

Entscheidungsfeld	Primärverantwortlich	Stellvertretend	Informationspflicht
Isolierung eines Systems	CERT	IT Ops	CISO
Externe Kommunikation	Management	PR	CISO, DPO
Behördenmeldung	DPO	CISO	Management
Wiederanlaufentscheidung	BCM	CERT	Management
Lessons Learned	CISO	CERT	Alle betroffenen Bereiche

Eine solche Matrix ist Teil vieler ISMS- oder BCP-Dokumentationen und schafft die Grundlage für **strukturierte Entscheidungsprozesse in Stresssituationen**.

9.5 Vom Konflikt zur Koordination

Konflikte werden dann gefährlich, wenn sie unstrukturiert bleiben. Resiliente Organisationen fördern deshalb **Cross-Role-Trainings**: SOC-Mitarbeitende lernen, wie BCM denkt, und CISO-Teams verstehen rechtliche Zwänge des DPO.

„Verstehen ersetzt Kontrolle – und erzeugt Respekt, der im Krisenfall trägt."

Solche interdisziplinären Trainings wirken wie Impfungen gegen Organisationschaos.

9.6 Fazit

Rollenreibung ist unvermeidlich – aber sie ist auch **die produktive Energie organisationaler Resilienz**. Statt Konflikte zu vermeiden, sollten sie **vorhersehbar gemacht, trainiert und moderiert** werden.

„Reibungslosigkeit ist kein Zeichen von Stabilität, sondern von Stillstand."

Resilienz entsteht dort, wo unterschiedliche Perspektiven zusammenkommen, ohne sich gegenseitig zu blockieren. Das erfordert Governance, Empathie und die Bereitschaft, Sicherheit als gemeinsamen Auftrag zu verstehen.

Kapitel 10 – Übung und Reflexion: Rollenmapping im Incident-Fall

Resilienz ist keine Theorie, sondern Verhalten unter Stress. Deshalb endet jede Sitzung zu organisationalen Themen mit einer **praktischen Gruppenübung**, die Kommunikation, Rollenverständnis und Entscheidungslogik in Echtzeit erlebbar macht.

10.1 Ziel der Übung

- Anwendung des gelernten Rollenmodells (CISO – SOC – CERT – DPO – BCM – IT Ops – Management).

- Verstehen der Eskalationslogik und Kommunikationswege.
- Reflexion über Konfliktpunkte und Verbesserungspotenziale.

Didaktischer Fokus: Trainieren von *Verantwortungsbewusstsein, Kommunikationspräzision und Team-Koordination* unter Zeitdruck.

10.2 Szenario: Angriff über Phishing mit privilegiertem Zugriff

Montagmorgen, 08:47 Uhr:

Ein Mitarbeitender im Finanzbereich öffnet eine E-Mail mit dem Betreff „Überweisungserlaubnis".

Innerhalb von Minuten melden sich mehrere Systeme im SOC mit verdächtigen Login-Versuchen aus dem Ausland.

Das CERT wird informiert – doch noch ist unklar, ob Daten exfiltriert wurden.

Parallel fordert das Management einen Bericht, und der DPO fragt nach der Meldepflicht. Das Telefon klingelt – die Presseabteilung hat Gerüchte über einen Cyberangriff gehört.

10.3 Aufgabenstellung für die Gruppenarbeit

In Gruppen von 4–5 Studierenden:

1. **Identifizieren Sie alle relevanten Rollen** in diesem Szenario.
2. **Ordnen Sie Verantwortlichkeiten** zu:
   - Wer reagiert zuerst?
   - Wer entscheidet über Systemabschaltungen?
   - Wer informiert das Management?
   - Wer bewertet rechtliche Verpflichtungen?
3. **Skizzieren Sie ein Kommunikationsmodell** mit Pfeilen zwischen Rollen.
4. **Definieren Sie einen Zeitplan** für Eskalation (z. B. SOC → CERT → CISO innerhalb x Minuten).
5. **Benennen Sie Konfliktpunkte** und schlagen Sie Governance- oder Prozessverbesserungen vor.

Zeit: 20 Minuten Gruppenarbeit + 15 Minuten Plenum.

10.4 Reflexion im Plenum

Diskussionsfragen:

1. Wo entstanden Unklarheiten oder Überschneidungen?
2. Welche Kommunikationswege waren unklar oder zu lang?
3. Welche Rolle hätte stärker eingebunden werden müssen?
4. Wie hätte psychologische Sicherheit (z. B. offenes Melden von Fehlern) geholfen?
5. Welche Lehren zieht das Team für die reale Organisation?

„Nicht die perfekte Struktur schützt – sondern die Fähigkeit, sie in der Krise gemeinsam zu nutzen."

10.5 Didaktische Hinweise

Diese Übung eignet sich hervorragend als **Brückenelement zwischen Technik und Organisation**.

Studierende erleben unmittelbar, dass Resilienz kein IT-Thema, sondern ein **menschlich-organisationales Zusammenspiel** ist.

Varianten lassen sich in späteren Sitzungen wieder aufnehmen (z. B. in Sitzung 8 „Messung und Steuerung“ mit KPIs).

10.6 Fazit der Sitzung

Nach Abschluss dieser Übung sollen die Studierenden:

- zentrale Rollen (CISO, SOC, CERT, DPO, BCM, IT Ops, Management) sicher zuordnen können,
- Kommunikationswege und Eskalationslogiken kennen,
- typische Konflikte und Lösungsmechanismen erkennen,
- und verstehen, dass **klare Verantwortlichkeiten gelebte Resilienz** sind.

„Struktur ist das Skelett der Resilienz – Kommunikation ist ihr Nervensystem.“

Prüfungsrelevante Leitfragen – Sitzung 6

Diese Leitfragen dienen der gezielten Wiederholung der zentralen Inhalte und Zusammenhänge.

Sie decken alle zehn Kapitel der Sitzung ab und sind in typischer Prüfungslogik (Verständnis-, Anwendungs- und Transferfragen) formuliert.

1. Grundlagen und Organisation

1. Warum sind klar definierte Rollen und Verantwortlichkeiten eine zentrale Voraussetzung organisationaler Resilienz?
2. Wie unterscheidet sich der Begriff *Verantwortung* von *Schuld* im Kontext von Cyber-Resilienz?
3. Welche organisatorischen Probleme entstehen, wenn Rollen unklar definiert sind?

2. CISO – Chief Information Security Officer

4. Welche Kernaufgaben und Befugnisse hat der CISO nach ISO/IEC 27001 und NIS-2?
5. Was bedeutet das „Mandatsdilemma“ des CISO und wie lässt es sich lösen?
6. Warum sollte der CISO unabhängig von der IT-Linie positioniert sein?
7. Welche Kompetenzen sind entscheidend, damit der CISO als „Enabler“ und nicht als „Bremse“ wahrgenommen wird?

3. SOC – Security Operations Center

8. Welche Hauptfunktionen erfüllt das SOC im Rahmen der Cyber-Resilienz?
9. Wie ist ein SOC typischerweise nach dem Tier-Modell aufgebaut und was sind die Vorteile dieser Struktur?
10. Welche Risiken entstehen bei unklarer Kommunikation zwischen SOC und CERT?
11. Was versteht man unter *Alarm Fatigue*, und welche Maßnahmen können dagegen helfen?

4. CERT – Computer Emergency Response Team

12. Welche Phasen umfasst der Incident Handling Cycle nach ISO/IEC 27035?
13. Welche Unterschiede bestehen zwischen Internal, Sectoral und National CERTs?
14. Warum ist das CERT zentral für organisationales Lernen?
15. Welche Erfolgskriterien kennzeichnen ein resilientes CERT?

5. Zusammenarbeit von CISO, SOC und CERT

16. Welche Aufgabenverteilung besteht zwischen CISO, SOC und CERT?

17. Was bedeutet das Prinzip „Trennung der Funktionen – Integration der Wirkung“?
18. Warum ist ein gemeinsames Lagebild („Single Source of Truth“) essenziell?
19. Wie unterscheiden sich Governance, Taktik und Operation im Zusammenspiel dieser drei Rollen?

6. Weitere Schlüsselrollen

20. Welche Rolle spielt der Datenschutzbeauftragte (DPO) im Incident-Fall?
21. Wie ergänzen sich CERT und BCM in der Wiederanlaufphase?
22. Welche Bedeutung hat die IT Operations-Abteilung für die Cyber-Resilienz?
23. Warum ist das Management Board letztlich Träger der Gesamtverantwortung für Informationssicherheit?

7. Kommunikation und Eskalation

24. Was sind die fünf Grundprinzipien resilienter Kommunikation?
25. Wie lässt sich eine Eskalationsstruktur mit operativer, taktischer und strategischer Ebene beschreiben?
26. Welche rechtlichen Meldepflichten ergeben sich aus DSGVO, NIS-2 und BSIG?
27. Warum ist psychologische Sicherheit eine Voraussetzung für funktionierende Krisenkommunikation?

8. Konflikte und Lösungsprinzipien

28. Nennen Sie drei typische Konfliktlinien zwischen Rollen in der Cyber-Organisation.
29. Wie kann eine Governance-Matrix helfen, diese Konflikte zu lösen?
30. Warum ist Reibung zwischen Rollen nicht destruktiv, sondern ein Merkmal lebender Organisationen?
31. Wie tragen Cross-Role-Trainings zur Resilienz bei?

9. Übung und Reflexion

32. Welche Rollen müssen in einem typischen Phishing-Incident zusammenarbeiten?
33. Wie unterscheiden sich operative, taktische und strategische Entscheidungen im Incident?
34. Was sind typische Fehler in Kommunikationsketten und wie lassen sich diese vermeiden?
35. Welche Lehren kann man aus der Rollenübung für reale Organisationen ziehen?

10. Meta-Fragen und Transfer

36. Wie hängen Rollen, Kommunikation und Kultur als Elemente organisationaler Resilienz zusammen?
37. Warum ist „Rollenbewusstsein“ eine Führungskompetenz?
38. Inwiefern kann man sagen, dass Resilienz durch Rollen „institutionalisiertes Vertrauen“ ist?
39. Welche Elemente aus Sitzung 6 finden sich in ISO 22316 (Organisational Resilience) wieder?
40. Was unterscheidet eine „resiliente“ von einer „robusten“ Organisation aus Sicht der Verantwortlichkeitsstruktur?

Hinweis für Studierende: Die Leitfragen 1–30 bilden die prüfungsrelevante Basis (Klausurwissen). Die Fragen 31–40 sind vertiefende Reflexions- oder Transferfragen, die sich gut für mündliche Prüfungen, Hausarbeiten oder Präsentationen eignen.

Bibliografie

[1] „ISO/IEC 27035-1: Information technology – Information security incident management – Part 1: Principles and process“. 2023.

[2] „Richtlinie (EU) 2022/2555 des Europäischen Parlaments und des Rates vom 14. Dezember 2022 über Maßnahmen für ein hohes gemeinsames Cybersicherheitsniveau in der Union (NIS-2-Richtlinie)“. [Online]. Verfügbar unter: https://eur-lex.europa.eu/eli/dir/2022/2555/oj